Identifying SQL Injection Vulnerabilities Using OWASP ZAP

https://pigeon-in.com/

1. Project Overview

This project focuses on identifying SQL Injection (SQLi) and other common web application vulnerabilities using OWASP ZAP (Zed Attack Proxy). The assessment was conducted on the target web application following ethical testing standards and industry best practices.

Both automated scanning and manual testing techniques were applied to detect potential security weaknesses such as:

- SQL Injection (SQLi)
- Cross-Site Scripting (XSS)
- Security Misconfigurations
- Insecure Authentication Mechanisms
- Sensitive Information Exposure

The goal of this project is to enhance the security posture of the web application by identifying vulnerabilities and recommending remediation measures.

2. Objective

The primary objectives of this security assessment were:

- Identify SQL Injection vulnerabilities in the target application
- Detect other OWASP Top 10 web application risks
- Perform proxy-based traffic analysis
- Validate findings through manual verification
- Generate detailed vulnerability reports
- Provide remediation recommendations

3. Tools & Technologies Used

Tool	Purpose
OWASP ZAP	Vulnerability scanning and proxy-based testing
Web Browser (Configured Proxy)	Intercepting and modifying requests
SQL Injection Payloads	Manual validation of injection points
HTTP Request/Response Analyzer	Traffic inspection

4. Methodology

The project followed a structured vulnerability assessment approach:

- **Phase 1: Environment Setup**
- Installed and configured OWASP ZAP.
- Configured browser proxy settings to route traffic through ZAP.
- Imported target website into ZAP session.

Phase 2: Passive Scanning

Browsed the web application normally.

ZAP automatically analyzed HTTP traffic.

Identified:

- Missing security headers
- Information disclosure
- Cookie security issues

Phase 3: Active Scanning

Conducted automated active scan.

Injected test payloads into:

- Input fields
- URL parameters
- Login forms
- Search boxes
- Monitored application responses for anomalies.

Phase 4: Manual SQL Injection Testing

Identified potential injection points.

Inserted SQL payloads such as:

' OR '1'='1

' UNION SELECT NULL--

Observed server responses:

- SQL error messages
- Authentication bypass
- Unexpected data exposure

Phase 5: Cross-Site Scripting Testing

Tested reflected and stored XSS.

Injected sample script payload:

<script>alert(1)</script>

Verified whether input was properly sanitized.

Phase 6: Risk Classification

Categorized vulnerabilities based on:

- Risk Level (High / Medium / Low)
- Impact Severity
- Exploitability

5. Key Findings

5.1 SQL Injection Vulnerabilities

- Identified input fields vulnerable to improper input validation.
- Database queries were not parameterized.
- Application exposed database error messages in some cases.

Risk Level: High

Impact: Data leakage, authentication bypass, database manipulation.

5.2 Cross-Site Scripting (XSS)

- Reflected XSS observed in search parameter.
- User input not properly encoded before rendering.

Risk Level: Medium

Impact: Session hijacking, phishing attacks, malicious script execution.

5.3 Security Misconfigurations

Missing security headers:

- Content-Security-Policy
- X-Frame-Options
- X-Content-Type-Options

Risk Level: Low to Medium

Impact: Clickjacking, MIME-sniffing attacks.

6. Risk Impact Analysis

If exploited, these vulnerabilities could lead to:

- Unauthorized database access
- Exposure of sensitive customer information
- Account takeover
- Reputation damage
- Legal and compliance issues

7. Remediation Recommendations

For SQL Injection:

- Use parameterized queries (Prepared Statements).
- Implement server-side input validation.
- Use ORM frameworks with secure query handling.
- Disable detailed database error messages in production.
- Implement Web Application Firewall (WAF).

For XSS:

- Apply proper input sanitization.
- Encode output before rendering in browser.
- Implement Content Security Policy (CSP).

For Security Headers:

Enable:

- Content-Security-Policy
- X-Frame-Options
- Strict-Transport-Security
- X-Content-Type-Options

8. Ethical Considerations

- Testing was conducted with proper authorization.
- No data was altered or deleted.
- No Denial-of-Service attempts were made.

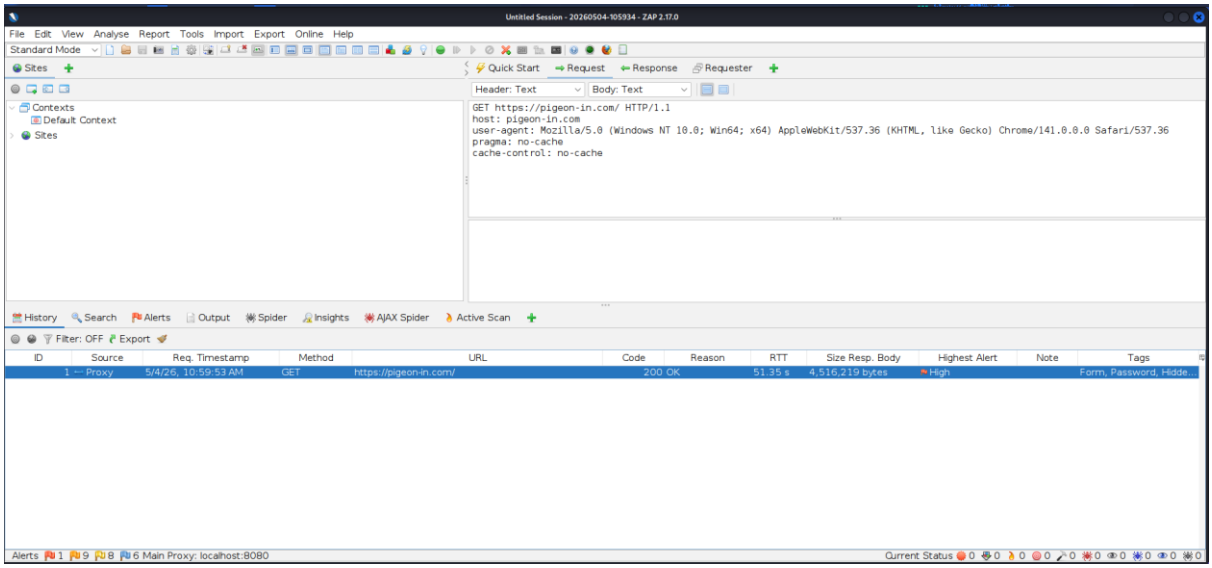
All findings are confidential and shared only with authorized stakeholders.

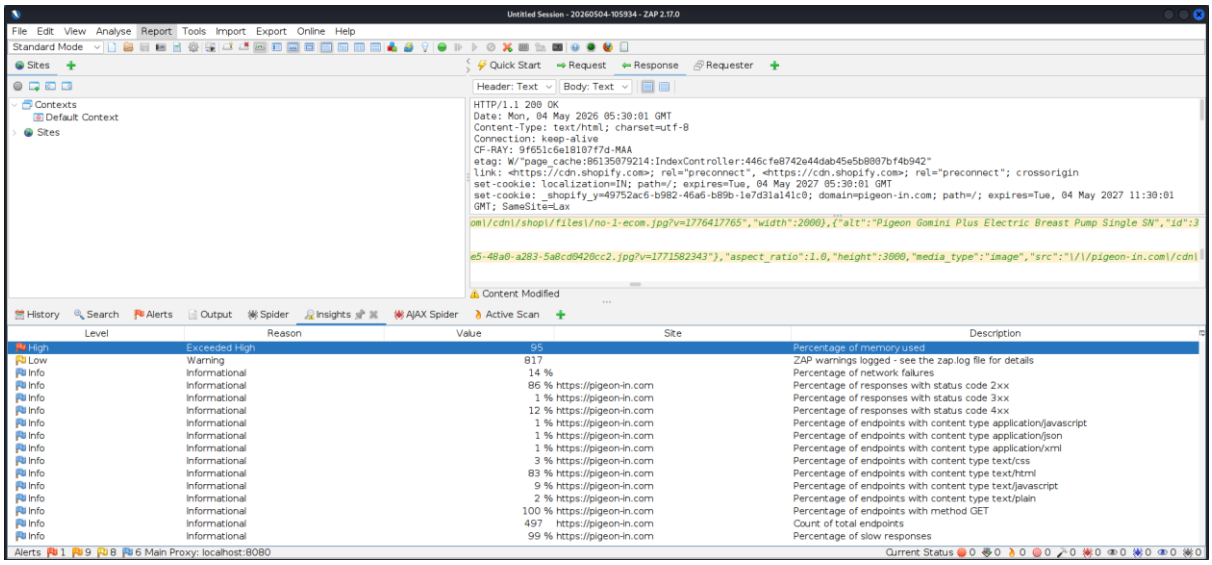
9. Deliverables

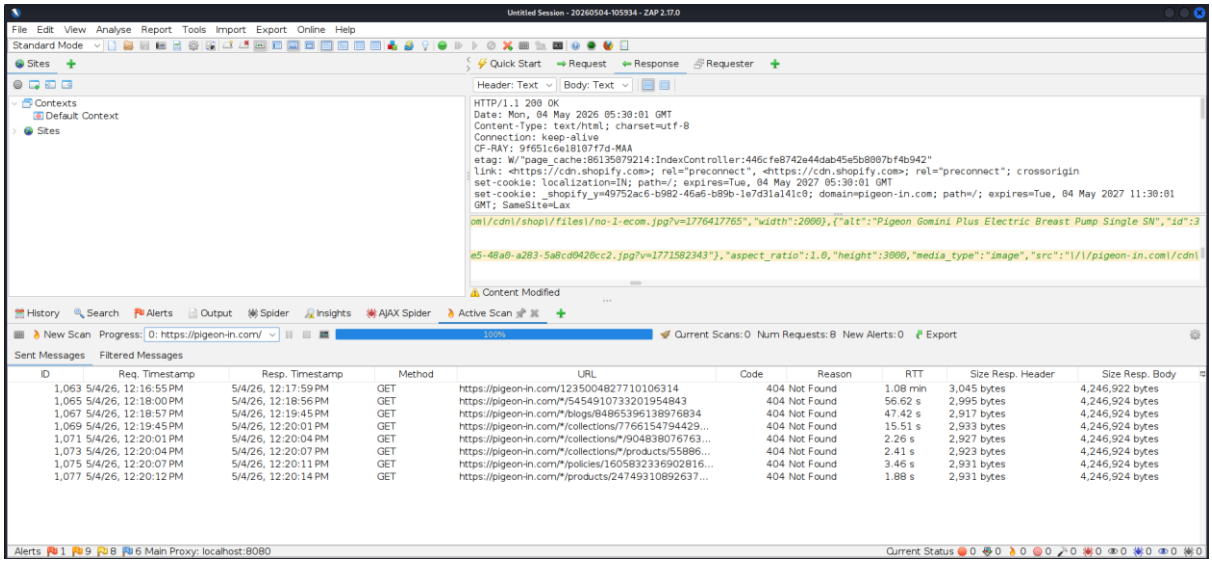
- OWASP ZAP Scan Report (PDF/HTML)
- Vulnerability Summary Report
- Risk Classification Sheet
- Remediation Guidance Document

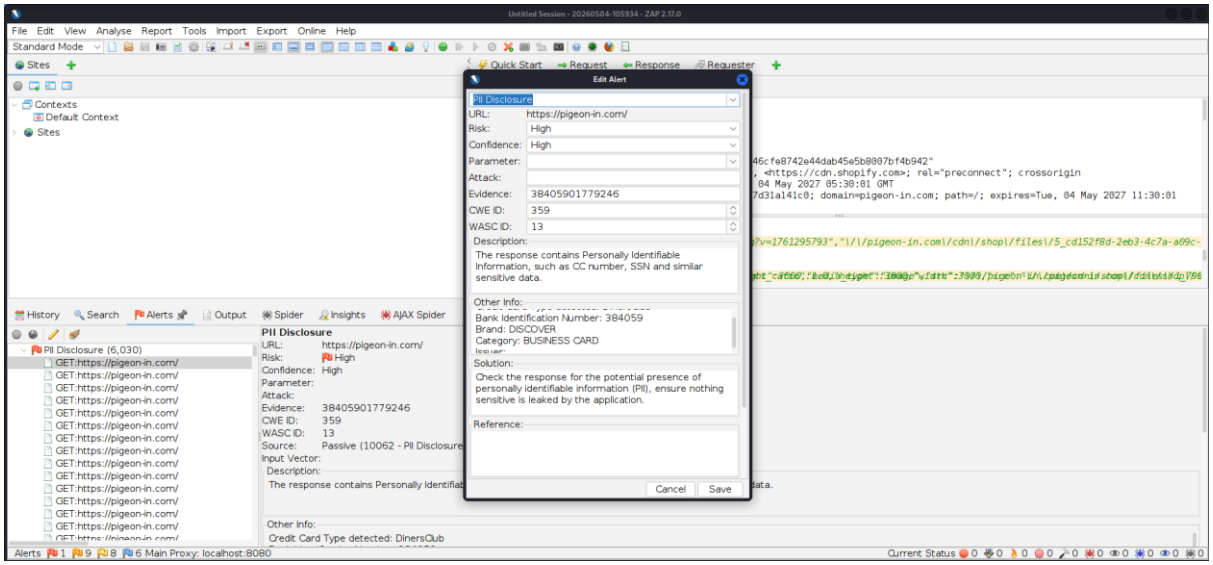
10. Conclusion

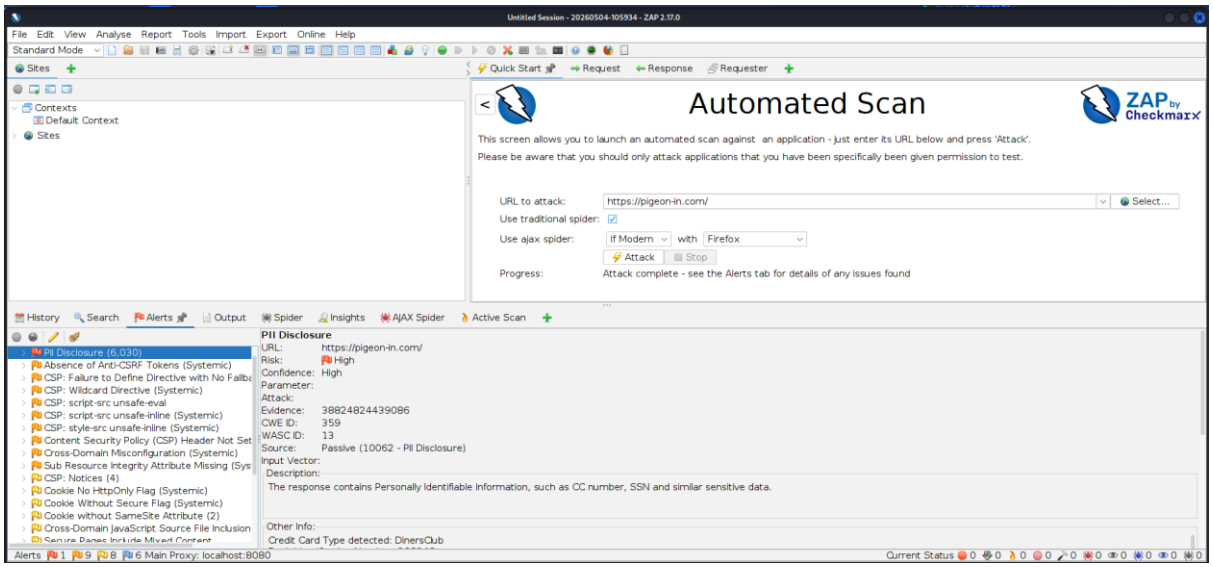
The assessment successfully identified SQL Injection and other web application vulnerabilities using OWASP ZAP. The combination of automated and manual testing provided comprehensive coverage of potential attack vectors. By implementing the recommended remediation measures, the organization can significantly improve its web application security posture and reduce exposure to cyber threats.

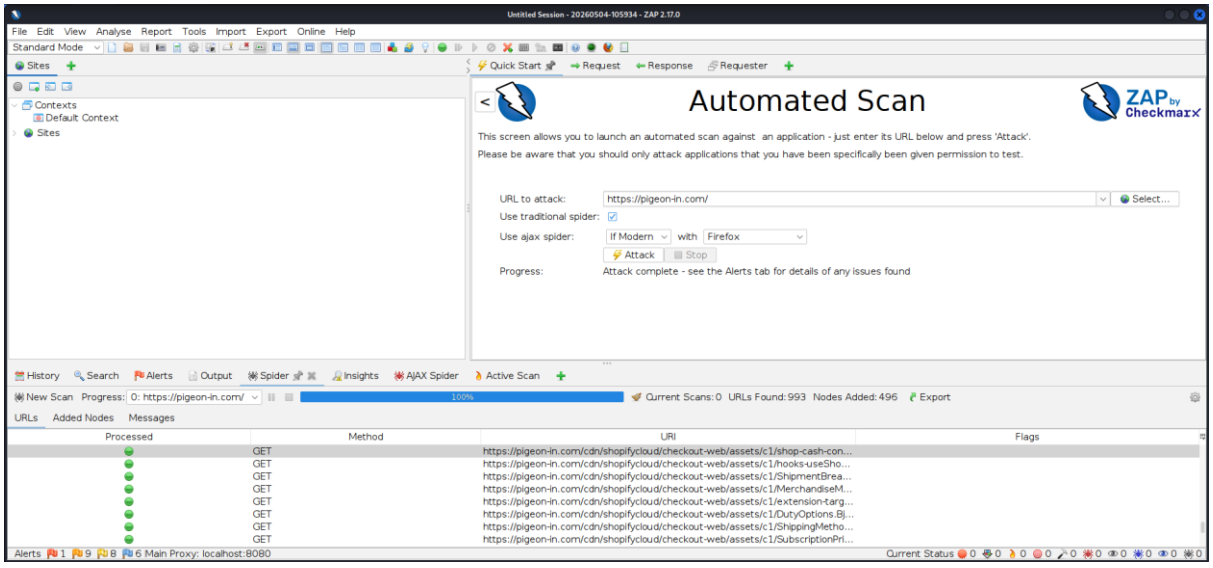

Untitled Session - 20260504-105934 - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Header: Text
Body: Text
Contexts
Default Context
Sites
GET https://pigeon-in.com/ HTTP/1.1
host: pigeon-in.com
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36
pragma: no-cache
cache-control: no-cache
History
Search
Alerts
Output
Spider
Insights
AJAX Spider
Active Scan
Filter: OFF
Export
ID Source Req. Timestamp Method URL Code Reason RTT Size Resp. Body Highest Alert Note Tags
1 Proxy 5/4/26, 10:59:53 AM GET https://pigeon-in.com/ 200 OK 51.35 s 4,516,219 bytes High Form, Password, Hidde...
Alerts 1 9 8 6 Main Proxy: localhost:8080
Current Status


Untitled Session - 20260504-105934 - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Header: Text
Body: Text
Contexts
Default Context
Sites
HTTP/1.1 200 OK
Date: Mon, 04 May 2026 05:30:01 GMT
Content-Type: text/html; charset=utf-8
Connection: keep-alive
CF-RAY: 9f651c6e18107f7d-MAA
etag: W/"page_cache:86135079214:IndexController:446cfe8742e44dab45e5b8007bf4b942"
link: <https://cdn.shopify.com>; rel="preconnect", <https://cdn.shopify.com>; rel="preconnect"; crossorigin
set-cookie: localization=IN; path=/; expires=Tue, 04 May 2027 05:30:01 GMT
set-cookie: _shopify_y=49752ac6-b982-46a6-b89b-1e7d31a141c0; domain=pigeon-in.com; path=/; expires=Tue, 04 May 2027 11:30:01 GMT; SameSite=Lax
om\/cdn\/shop\/files\/no-1-ecom.jpg?v=1776417765","width":2000},{"alt":"Pigeon Gomini Plus Electric Breast Pump Single SN","id":3
e5-48a0-a283-5a8cd0420cc2.jpg?v=1771582343"},"aspect_ratio":1.0,"height":3000,"media_type":"image","src":"\/\/pigeon-in.com\/cdn\
Content Modified
History
Search
Alerts
Output
Spider
Insights
AJAX Spider
Active Scan
Level Reason Value Site Description
High Exceeded High 95 Percentage of memory used
Low Warning 817 ZAP warnings logged - see the zap.log file for details
Info Informational 14 % Percentage of network failures
Info Informational 86 % https://pigeon-in.com Percentage of responses with status code 2xx
Info Informational 1 % https://pigeon-in.com Percentage of responses with status code 3xx
Info Informational 12 % https://pigeon-in.com Percentage of responses with status code 4xx
Info Informational 1 % https://pigeon-in.com Percentage of endpoints with content type application/javascript
Info Informational 1 % https://pigeon-in.com Percentage of endpoints with content type application/json
Info Informational 1 % https://pigeon-in.com Percentage of endpoints with content type application/xml
Info Informational 3 % https://pigeon-in.com Percentage of endpoints with content type text/css
Info Informational 83 % https://pigeon-in.com Percentage of endpoints with content type text/html
Info Informational 9 % https://pigeon-in.com Percentage of endpoints with content type text/javascript
Info Informational 2 % https://pigeon-in.com Percentage of endpoints with content type text/plain
Info Informational 100 % https://pigeon-in.com Percentage of endpoints with method GET
Info Informational 497 https://pigeon-in.com Count of total endpoints
Info Informational 99 % https://pigeon-in.com Percentage of slow responses
Alerts 1 9 8 6 Main Proxy: localhost:8080
Current Status


Untitled Session - 20260504-105934 - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Header: Text
Body: Text
Contexts
Default Context
Sites
HTTP/1.1 200 OK
Date: Mon, 04 May 2026 05:30:01 GMT
Content-Type: text/html; charset=utf-8
Connection: keep-alive
CF-RAY: 9f651c6e18107f7d-MAA
etag: W/"page_cache:86135079214:IndexController:446cfe8742e44dab45e5b8007bf4b942"
link: <https://cdn.shopify.com>; rel="preconnect", <https://cdn.shopify.com>; rel="preconnect"; crossorigin
set-cookie: localization=IN; path=/; expires=Tue, 04 May 2027 05:30:01 GMT
set-cookie: _shopify_y=49752ac6-b982-46a6-b89b-1e7d31a141c0; domain=pigeon-in.com; path=/; expires=Tue, 04 May 2027 11:30:01 GMT; SameSite=Lax
om\/cdn\/shop\/files\/no-1-ecom.jpg?v=1776417765","width":2000},{"alt":"Pigeon Gomini Plus Electric Breast Pump Single SN","id":3
e5-48a0-a283-5a8cd0420cc2.jpg?v=1771582343"},"aspect_ratio":1.0,"height":3000,"media_type":"image","src":"\/\/pigeon-in.com\/cdn\
Content Modified
History
Search
Alerts
Output
Spider
Insights
AJAX Spider
Active Scan
New Scan
Progress: 0: https://pigeon-in.com/
100%
Current Scans: 0 Num Requests: 8 New Alerts: 0
Export
Sent Messages
Filtered Messages
ID Req. Timestamp Resp. Timestamp Method URL Code Reason RTT Size Resp. Header Size Resp. Body
1,063 5/4/26, 12:16:55 PM 5/4/26, 12:17:59 PM GET https://pigeon-in.com/1235004827710106314 404 Not Found 1.08 min 3,045 bytes 4,246,922 bytes
1,065 5/4/26, 12:18:00 PM 5/4/26, 12:18:56 PM GET https://pigeon-in.com/*/5454910733201954843 404 Not Found 56.62 s 2,995 bytes 4,246,924 bytes
1,067 5/4/26, 12:18:57 PM 5/4/26, 12:19:45 PM GET https://pigeon-in.com/*/blogs/84865396138976834 404 Not Found 47.42 s 2,917 bytes 4,246,924 bytes
1,069 5/4/26, 12:19:45 PM 5/4/26, 12:20:01 PM GET https://pigeon-in.com/*/collections/7766154794429... 404 Not Found 15.51 s 2,933 bytes 4,246,924 bytes
1,071 5/4/26, 12:20:01 PM 5/4/26, 12:20:04 PM GET https://pigeon-in.com/*/collections/*/904838076763... 404 Not Found 2.26 s 2,927 bytes 4,246,924 bytes
1,073 5/4/26, 12:20:04 PM 5/4/26, 12:20:07 PM GET https://pigeon-in.com/*/collections/*/products/55886... 404 Not Found 2.41 s 2,923 bytes 4,246,924 bytes
1,075 5/4/26, 12:20:07 PM 5/4/26, 12:20:11 PM GET https://pigeon-in.com/*/policies/16058323369028 16... 404 Not Found 3.46 s 2,931 bytes 4,246,924 bytes
1,077 5/4/26, 12:20:12 PM 5/4/26, 12:20:14 PM GET https://pigeon-in.com/*/products/24749310892637... 404 Not Found 1.88 s 2,931 bytes 4,246,924 bytes
Alerts 1 9 8 6 Main Proxy: localhost:8080
Current Status


Untitled Session - 20260504-105934 - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
Sites
Edit Alert
PII Disclosure
URL: https://pigeon-in.com/
Risk: High
Confidence: High
Parameter:
Attack:
Evidence: 38405901779246
CWE ID: 359
WASC ID: 13
Description:
The response contains Personally Identifiable Information, such as CC number, SSN and similar sensitive data.
Other Info:
Bank Identification Number: 384059
Brand: DISCOVER
Category: BUSINESS CARD
Solution:
Check the response for the potential presence of personally identifiable information (PII), ensure nothing sensitive is leaked by the application.
Reference:
Cancel
Save
History
Search
Alerts
Output
Spider
Insights
AJAX Spider
PII Disclosure (6,030)
GET:https://pigeon-in.com/
PII Disclosure
URL: https://pigeon-in.com/
Risk: High
Confidence: High
Parameter:
Attack:
Evidence: 38405901779246
CWE ID: 359
WASC ID: 13
Source: Passive (10062 - PII Disclosure
Input Vector:
Description:
Other Info:
Credit Card Type detected: DinersQub
Alerts 1 9 8 6 Main Proxy: localhost:8080
Current Status


Untitled Session - 20260504-105934 - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
Sites
Automated Scan
ZAP by Checkmarx
This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'.
Please be aware that you should only attack applications that you have been specifically been given permission to test.
URL to attack: https://pigeon-in.com/
Select...
Use traditional spider:
Use ajax spider: If Modern with Firefox
Attack
Stop
Progress: Attack complete - see the Alerts tab for details of any issues found
History
Search
Alerts
Output
Spider
Insights
AJAX Spider
Active Scan
PII Disclosure (6,030)
Absence of Anti-CSRF Tokens (Systemic)
CSP: Failure to Define Directive with No Fallbac
CSP: Wildcard Directive (Systemic)
CSP: script-src unsafe-eval
CSP: script-src unsafe-inline (Systemic)
CSP: style-src unsafe-inline (Systemic)
Content Security Policy (CSP) Header Not Set
Cross-Domain Misconfiguration (Systemic)
Sub Resource Integrity Attribute Missing (Sys
CSP: Notices (4)
Cookie No HttpOnly Flag (Systemic)
Cookie Without Secure Flag (Systemic)
Cookie without SameSite Attribute (2)
Cross-Domain JavaScript Source File Inclusion
PII Disclosure
URL: https://pigeon-in.com/
Risk: High
Confidence: High
Parameter:
Attack:
Evidence: 38824824439086
CWE ID: 359
WASC ID: 13
Source: Passive (10062 - PII Disclosure)
Input Vector:
Description:
The response contains Personally Identifiable Information, such as CC number, SSN and similar sensitive data.
Other Info:
Credit Card Type detected: DinersQub
Alerts 1 9 8 6 Main Proxy: localhost:8080
Current Status


Untitled Session - 20260504-105934 - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
Sites
Automated Scan
ZAP by Checkmarx
This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'.
Please be aware that you should only attack applications that you have been specifically been given permission to test.
URL to attack: https://pigeon-in.com/
Select...
Use traditional spider:
Use ajax spider: If Modern with Firefox
Attack
Stop
Progress: Attack complete - see the Alerts tab for details of any issues found
History
Search
Alerts
Output
Spider
Insights
AJAX Spider
Active Scan
New Scan
Progress: 0: https://pigeon-in.com/
100%
Current Scans: 0 URLs Found: 993 Nodes Added: 496
Export
URLs
Added Nodes
Messages
Processed
Method
URI
Flags
GET https://pigeon-in.com/cdn/shopifycloud/checkout-web/assets/c1/shop-cash-con...
GET https://pigeon-in.com/cdn/shopifycloud/checkout-web/assets/c1/hooks-useSho...
GET https://pigeon-in.com/cdn/shopifycloud/checkout-web/assets/c1/ShipmentBrea...
GET https://pigeon-in.com/cdn/shopifycloud/checkout-web/assets/c1/MerchandiseM...
GET https://pigeon-in.com/cdn/shopifycloud/checkout-web/assets/c1/extension-targ...
GET https://pigeon-in.com/cdn/shopifycloud/checkout-web/assets/c1/DutyOptions.Bj...
GET https://pigeon-in.com/cdn/shopifycloud/checkout-web/assets/c1/ShippingMetho...
GET https://pigeon-in.com/cdn/shopifycloud/checkout-web/assets/c1/SubscriptionPri...
Alerts 1 9 8 6 Main Proxy: localhost:8080
Current Status